

Министерство образования Республики Беларусь

Учреждение образования
«БЕЛОРУССКИЙ ГОСУДАРСТВЕННЫЙ УНИВЕРСИТЕТ
ИНФОРМАТИКИ И РАДИОЭЛЕКТРОНИКИ»

Факультет информационных технологий и управления
Кафедра интеллектуальных информационных технологий

Лабораторная работа №4

по дисциплине «Проектирование защищенных интеллектуальных
информационных систем»

на тему «Безопасность работы серверов в сети Internet.

Часть 2. Усовершенствование системы безопасности удалённых серверов»

Выполнил студент гр. 321701

Ковальчук В. Н.
Самович В. М.

Проверил

Сальников Д. А.

Минск 2026

Цель: получить практические навыки установки, настройки и применения системы обнаружения/предотвращения вторжений (IDS/IPS) для защиты реального удалённого сервера, а также навыки сравнительного анализа сетевой активности до и после её внедрения.

Задание:

а) Установить и настроить программное обеспечение, позволяющее усовершенствовать защиту сервера, согласно варианту.

б) Выполнить анализ данных логов различных подсистем, в том числе SSH и веб-сервера удалённого сервера, за несколько дней.

в) Оформить отчёт о проделанной работе.

Постановка задачи. В качестве варианта выбран OSSEC – система обнаружения вторжений на основе хоста (HIDS) с возможностью активного ответа (то есть способная работать и как IPS). Она установлена на том же сервере (`test-lab4.work.gd`), что использовался в лабораторной работе №4.1, и настроена на мониторинг тех же подсистем – SSH и веб-сервера Caddy, – чтобы можно было напрямую сравнить сетевую активность и её обработку до появления OSSEC (данные лабораторной работы №4.1) и после включения его активного ответа.

Описание установленного программного обеспечения

OSSEC – система обнаружения вторжений на основе хоста (HIDS), устанавливаемая непосредственно на защищаемый сервер, а не работающая на отдельном сетевом сенсоре (в отличие, например, от Snort или Suricata). Задачи, которые она решает:

- **Анализ журналов (log analysis)** – построчное чтение указанных лог-файлов, разбор записи декодерами (для распознанных форматов, включая формат `sshd`) и сопоставление с базой правил обнаружения; при совпадении формируется тревога с уровнем критичности.

- **Контроль целостности файлов (syscheck/FIM)** – периодическая проверка контрольных сумм важных файлов системы на предмет несанкционированного изменения.

- **Обнаружение руткитов (rootcheck)** – проверка признаков скомпрометированной системы (аномальные записи в системных структурах, известные сигнатуры).

- **Активный ответ (active response)** – при тревоге выше заданного порога критичности автоматически выполняется команда реагирования: в данном случае `firewall-drop` (добавление правила `iptables DROP` для IP-источника) и `host-deny` (запись в `/etc/hosts.deny`), на 600 секунд. Именно эта возможность превращает систему из чисто наблюдающей (IDS) в способную самостоятельно вмешиваться (IPS).

Принцип работы. OSSEC установлен в режиме `local` (сервер и агент совмещены на одной машине, что уместно для единственного защищаемого хоста) из исходного кода (готового пакета для Ubuntu 24.04 нет). Отдельные процессы-демоны выполняют разные роли: `ossec-logcollector` читает указанные файлы и передаёт новые строки `ossec-analysisd`, который применяет декодеры и правила; при срабатывании правила уровня 6 и выше `ossec-execd` запускает соответствующий скрипт активного ответа. Отдельно настроен список исключений (`allow_list`) – IP-адреса и подсети, которые не блокируются активным ответом ни при каких обстоятельствах (публичный адрес самого сервера и внутренняя подсеть, через которую администратор подключается по VPN) – без этого существует риск, что система заблокирует легитимный, но интенсивный доступ, включая доступ самого администратора.

Анализируемые подсистемы и файлы

Анализируемые подсистемы – те же, что и в лабораторной работе №4.1: служба SSH (`sshd`) и веб-сервер `Caddy`, – с добавлением самого OSSEC как третьей подсистемы, чьи собственные журналы теперь тоже являются предметом анализа.

- `/var/log/auth.log` и `/var/log/caddy/access.log` – те же файлы, что описаны в отчёте по лабораторной работе №4.1; теперь они читаются не только вручную, но и потоково самим OSSEC.

- `/var/ossec/logs/alerts/alerts.log` – журнал всех тревог OSSEC с указанием сработавшего правила, его уровня критичности, исходного события и, если оно было определено, IP-адреса источника.

- `/var/ossec/logs/active-responses.log` – журнал именно исполненных действий активного ответа: какой IP, когда и на какой срок был заблокирован. Это основной источник данных для демонстрации перехода от обнаружения к предотвращению.

Анализ запросов из сети Internet до и после настройки

Периоды и методика сравнения. Период «до» – данные лабораторной работы №4.1: с 3 сентября 19:41 до 5 сентября 19:16 UTC ($\approx 47,6$ ч). Период «после» – с момента запуска OSSEC (5 сентября 19:16, запись «Ossec server started») по 20 сентября 21:19 (362,1 ч, ≈ 15 суток). Периоды разной длины, поэтому сравниваются нормированные показатели (в час, в сутки, на один адрес), а не абсолютные числа. Данные получены скриптом `analyze_logs.py` (листинг 1).

Показатель (SSH)	До OSSEC	После OSSEC
Неудачных попыток входа, всего	13 458	21 108
Неудачных попыток в час	283	58
То же без самого активного адреса	136	58
Попыток под несуществующими именами в час	62,5	22,3
Уникальных IP-адресов в сутки	32,3	23,4
Попыток на один IP в среднем	210	60
Максимум попыток с одного IP (доля от всех)	7 002 (52,0 %)	1 867 (8,8 %)
Доля попыток под <code>root</code>	71,7 %	51,5 %
Успешных входов с адресов, замеченных в переборе	0	0

Таблица 1 – Сравнение попыток входа по SSH до и после запуска OSSEC

Результат. Интенсивность неудачных попыток снизилась с 283 до 58 в час (на 79 %; на 57 % – если исключить единичный выброс периода «до», когда один адрес дал 7 002 попытки). Значимо изменилась структура: среднее число попыток на один адрес упало с 210 до 60, а доля самого активного адреса – с 52 % до 8,8 %, то есть ни один источник больше не может безнаказанно вести перебор в течение суток. Число же *уникальных источников* осталось того же порядка (23 в сутки против 32): OSSEC ограничивает то, сколько один адрес может сделать, но не то, сколько адресов приходит – сканеры не «обучаются» на блокировке, а просто получают её и продолжают со следующим адресом. Доступа не получил ни один адрес, замеченный в переборе: все успешные входы за период – с адреса VPN администратора 10.0.0.4.

Работа активного ответа. За период OSSEC создал 55 316 тревог, из них 49 667 (90 %) – уровня 5 (единичные неудачные входы, до порога активного ответа), 3 204 – уровня 10 (перебор, многократные неудачи) и 364 – уровня 13 (ложные, см. ниже). Активный ответ (уровень ≥ 6) выполнен 2 103 раза против 133 уникальных адресов (≈ 139 блокировок в сутки); 2 099 из них уже сняты по истечении 600 с, остальные действовали на момент анализа. Первая блокировка (5 сентября 19:44:34) выполнена через 28 минут после запуска; она вызвана правилом 2502 (листинг 3): каждая блокировка записывается в журнал дважды – командами `host-deny` и `firewall-drop`, и в системе видно как правило `iptables DROP`, так и запись в `/etc/hosts.deny`. Настроенный `allow_list` сработал ожидаемо: собственный адрес сервера и подсеть VPN ни разу не попали в журнал блокировок.

Ограничения активного ответа. Анализ выявил три слабых места.

а) **Постоянные источники возвращаются после каждой блокировки.** 83 из 133 адресов блокировались более одного раза, а восемь

самых частых (две подсети – 45.148.10.0/24, 62.60.130.0/24 – и адрес 193.47.62.69) дали 1289 из 2103 блокировок (61%); рекордсмен 45.148.10.152 заблокирован 188 раз. Фиксированный срок 600 с лишь прерывает перебор на 10 минут – затем он возобновляется.

б) **«Медленный» перебор остаётся незамеченным.** Два самых активных источника после включения OSSEC – 103.97.215.11 (1867 попыток) и 2.57.121.112 (1285) – ни разу не были заблокированы: правило 5712 срабатывает при 6 событиях 5710 за 120 с, тогда как 103.97.215.11 вёл перебор неделю (с 7 по 14 сентября) темпом около 11 попыток в час – при таком темпе порог не достигается никогда.

в) **Веб-трафик OSSEC не анализирует вовсе.** Файл /var/log/caddy/access.log подключён к OSSEC в формате syslog, а Caddy пишет журнал в JSON, который стандартные декодеры не разбирают: за 15 суток не сработало ни одного веб-правила (серия 31xxx), несмотря на то, что в журнале 1318 ответов 404, в том числе многочисленные пробы /.env и /.git/config. Обращения к этому файлу породили лишь 329 бесполезных тревог, а JSON-строки Caddy, попадающие также в /var/log/syslog, вызывают тревоги правила 1003 уровня 13 («size too large»; всего таких тревог 364) – самые «серьёзные» тревоги в журнале оказались ложными.

Веб-сервер. Для веб-трафика сравнение «до/после» количественно невозможно: база «до» составляет 26 минут (122 запроса, см. отчёт №4.1). Все 15 суток «после» получено 1642 запроса с 130 адресов, из которых 80,3% – 404. Трафик неравномерен: запросов в сутки от 3 до 421, причём четыре часовых «пакета» по 277 запросов (7, 9, 10 и 14 сентября) – 1108 запросов (67,5%) – пришли с четырёх адресов из блока 34.x.x.x, из них 1103 – 404 на пути вроде /.env, /.git/config, /.env.production. После 14 сентября интенсивность веб-сканирования упала до нескольких десятков запросов в сутки, тогда как для SSH она остаётся постоянной (1057–1923 попыток в сутки с 6 по 20 сентября). OSSEC на журнал веб-сервера, как и следовало из его конфигурации, не влияет.

```

1 Log analysis window: 2026-09-05T19:16 .. now generated 2026-09-20 21:21
2 =====
3 SSH (/var/log/auth.log*)
4 =====
5 Period covered by data: 2026-09-05 .. 2026-09-20
6 Failed authentication attempts: 21108 (by method: {'password': 21080, 'none': 28})
7 'Invalid user' events (unknown login name): 8057
8 Connections dropped before authentication ([preauth]): 16919
9 Unique source IPs with failed attempts: 353
10 Successful logins: 25
11
12 =====
13 OSSEC
14 =====
15 Alerts in window: 55316 by level: {2: 1586, 3: 133, 4: 197, 5: 49667, 7: 132, 8: 33, 10: 3204, 13: 364}
16
17 Top 10 rules:
18 20435 rule 5710 lvl 5 Attempt to login using a non-existent user
19 18509 rule 5503 lvl 5 User login failed.
20 10674 rule 5716 lvl 5 SSHD authentication failed.
21 2325 rule 2502 lvl 10 User missed the password more than one time
22 1576 rule 1002 lvl 2 Unknown problem somewhere in the system.
23 555 rule 5712 lvl 10 SSHD brute force trying to get access to the system.
24 364 rule 1003 lvl 13 Non standard syslog message (size too large).
25 230 rule 5551 lvl 10 Multiple failed logins in a small period of time.
26 188 rule 5740 lvl 4 ssh connection reset by peer
27 94 rule 5720 lvl 10 Multiple SSHD authentication failures.
28
29 Top 10 alert source IPs:
30 4600 103.97.215.11
31 2393 2.57.121.112
32 1845 2.57.121.25
33 1481 103.54.100.252
34 1337 202.165.25.8
35 1334 193.46.255.86
36 1208 193.187.110.213
37 1107 80.94.92.234
38 947 92.118.39.77
39 936 2.57.122.238
40
41 Active-response block events (one per ban, host-deny + firewall-drop counted once): 2103 against 133 unique
42 ↪ IPs; unblocks (ban expired): 2099
43 IPs banned more than once (returned after the 600 s ban expired): 83 of 133
44 Top 10 most-banned IPs:
45 188 45.148.10.152 first ban: Sun Sep 6 00:05:45
46 180 45.148.10.141 first ban: Sat Sep 5 22:12:16
47 179 193.47.62.69 first ban: Sat Sep 5 22:56:51
48 177 45.148.10.151 first ban: Sat Sep 5 22:32:07
49 172 45.148.10.157 first ban: Sat Sep 5 22:06:48
50 154 62.60.130.253 first ban: Sat Sep 5 23:21:20
51 147 62.60.130.242 first ban: Sat Sep 5 22:42:08
52 92 62.60.130.201 first ban: Sat Sep 5 23:06:39
53 56 193.46.255.86 first ban: Sat Sep 5 19:44:34
54 24 109.160.32.63 first ban: Fri Sep 11 18:33:04

```

Листинг 1 – Сводка по SSH, веб-серверу и OSSEC за 5–20 сентября (после запуска OSSEC)

Сравнение с аналогами

Система	Тип	Источник данных	Особенность
OSSEC	HIDS (+active response)	Логи файлов на хосте	Лёгкая установка на один сервер, встроенный IPS-режим через скрипты
Snort	NIDS/NIPS	Сетевые пакеты (libpcap)	Классический сигнатурный анализ трафика, требует описания правил под протокол
Suricata	NIDS/NIPS	Сетевые пакеты, многопоточность	Совместим с правилами Snort, дополнительно разбирает прикладные протоколы (HTTP, TLS и т. д.)
Tripwire	HIDS (только FIM)	Контрольные суммы файлов	Узкоспециализирован на контроле целостности, не анализирует сетевой трафик и логи в реальном времени
Zeek (Bro)	NIDS (анализ, не блокировка)	Сетевые пакеты	Ориентирован на подробное протоколирование и последующий анализ, а не на немедленную блокировку

Таблица 2 – OSSEC и альтернативные варианты задания

Для единственного сервера с ограниченным набором подсистем (SSH и один веб-сервер) выбор HIDS-решения, читающего уже существующие логи, вместо NIDS-решения, анализирующего сырой сетевой трафик, обоснован меньшими требованиями к настройке (не нужно описывать сигнатуры для протоколов) и меньшей нагрузкой на единственный процессор сервера.

Демонстрация работы установленного программного обеспечения

Снимок конфигурации активного ответа и белого списка приведён в листинг 2, а выдержки из журналов OSSEC, показывающие полный цикл «тревога → блокировка → снятие блокировки», – в листинг 3.

```

1 <global>
2   <allow_list>127.0.0.1</allow_list>
3   <allow_list>::1</allow_list>
4   <allow_list>212.192.9.89</allow_list>
5   <allow_list>10.0.0.0/24</allow_list>
6 </global>
7
8 <active-response>
9   <command>host-deny</command>
10  <location>local</location>
11  <level>6</level>
12  <timeout>600</timeout>
13 </active-response>
14 <active-response>
15   <command>firewall-drop</command>
16   <location>local</location>
17   <level>6</level>
18   <timeout>600</timeout>
19 </active-response>
20
21 <localfile><log_format>syslog</log_format><location>/var/log/auth.log</location></localfile>
22 <localfile><log_format>syslog</log_format><location>/var/log/syslog</location></localfile>
23 <localfile><log_format>syslog</log_format><location>/var/log/dpkg.log</location></localfile>
24 <localfile><log_format>syslog</log_format><location>/var/log/caddy/access.log</location></localfile>

```

Листинг 2 – Фрагмент конфигурации OSSEC: белый список, активный ответ и источники журналов

```

1 == /var/ossec/logs/alerts/alerts.log : brute-force alert (rule 5712, level 10) ==
2 ** Alert 1789862739.45135: mail - syslog,sshd,authentication_failures,
3 2026 Sep 20 00:05:39 weaselcloud-3522->/var/log/auth.log
4 Rule: 5712 (level 10) -> 'SSHD brute force trying to get access to the system.'
5 Src IP: 109.160.32.83
6 2026-09-20T00:05:37.278233+00:00 weaselcloud-3522 sshd[335280]: Invalid user user from 109.160.32.83 port
7   ↳ 35172
8 2026-09-20T00:05:19.628712+00:00 weaselcloud-3522 sshd[335272]: Failed password for invalid user hduser from
9   ↳ 109.160.32.83 port 35410 ssh2
10
11 == /var/ossec/logs/alerts/alerts.log : Caddy JSON line the SSH-oriented decoders cannot parse (rule 1003,
12   ↳ level 13) ==
13 Rule: 1003 (level 13) -> 'Non standard syslog message (size too large).'
14 2026-09-20T03:20:40.822244+00:00 weaselcloud-3522 caddy[84848]:
15   ↳ {"level":"info","ts":1789874440.8216176,"logger":"http.log.access","msg":"handled
16   ↳ request","request":{"remote_ip":"64.23.237.42", ...
17
18 == /var/ossec/logs/active-responses.log : first ban issued after OSSEC was started ==
19 Sat Sep 5 19:44:34 UTC 2026 /var/ossec/active-response/bin/host-deny.sh add - 193.46.255.86 1788637474.69
20   ↳ 2502
21 Sat Sep 5 19:44:34 UTC 2026 /var/ossec/active-response/bin/firewall-drop.sh add - 193.46.255.86 1788637474.69
22   ↳ 2502
23 Sat Sep 5 19:55:05 UTC 2026 /var/ossec/active-response/bin/host-deny.sh delete - 193.46.255.86 1788637474.69
24   ↳ 2502
25
26 == iptables -S | grep DROP (bans active at the time of analysis) ==
27 -A OSSEC -s 45.148.10.152/32 -j DROP
28 -A OSSEC -s 193.47.62.69/32 -j DROP
29 -A OSSEC -s 62.60.130.242/32 -j DROP
30
31 == /etc/hosts.deny (tail) ==
32 ALL:62.60.130.242
33 ALL:193.47.62.69
34 ALL:45.148.10.152

```

Листинг 3 – Примеры записей OSSEC: тревога, блокировка, снятие блокировки, активные правила

Выводы

Семантически лабораторная работа показала разницу между обнаружением и предотвращением. Журналирование из лабораторной работы №4.1 давало знание о происходящем (283 неудачные попытки входа в час, один адрес – 52 % всех), но не влияло на него. После включения OSSEC с активным ответом интенсивность упала до 58 попыток в час (на 79 %), а максимальная доля одного адреса – до 8,8 %: за 15 суток выполнено 2 103 автоматических блокировок 133 адресов. Вместе с тем число *уникальных* источников в сутки почти не изменилось (23 против 32): система ограничивает возможности каждого источника, но не отпугивает новые. Работа также показала границы такой защиты. Пороговое правило пропускает «медленный» перебор (два самых активных источника – 1 867 и 1 285 попыток – ни разу не блокировались); фиксированный срок блокировки в 600 с не останавливает настойчивых нападающих (восемь адресов дали 61 % всех блокировок, рекордсмен – 188); а JSON-журнал веб-сервера декодерами OSSEC не разбирается, поэтому 1 318 ответов 404 и пробы /.env остались без реакции.

С прагматической точки зрения выбор HIDS оправдал себя для одного сервера: установка из исходников на единственный хост, чтение уже существующих журналов, встроенный IPS-режим через **iptables** – без отдельного сенсора и без необходимости расшифровывать TLS. Практически полезные доработки, следующие из анализа: эскалация срока блокировки для повторяющихся адресов (10 мин → часы → сутки), правило по числу неудач за длинный период для «медленного» перебора, замена формата журнала Caddy или добавление собственного декодера для JSON, чтобы подключить веб-правила 31xxx, и главное – отключение **PasswordAuthentication** и **PermitRootLogin**, что делает подбор пароля бесполезным независимо от работы IDS. Наконец, сама система стала источником полезных данных – журнал **active-responses.log** позволяет выявлять настойчивые сети (45.148.10.0/24, 62.60.130.0/24), которых до её установки просто не существовало в виде отдельной статистики.